OFF-BY-ONE-2026 · Keynote · SINGAPORE

A Year of Hacking with LLMs

Zhiniang Peng

September 14, 2026

Zhiniang Peng

- Associated professor @ Huazhong University of Science and Technology (HUST)
- PhD in Cryptography
- Work in Defensive & Offensive security
- Published many research in both Industry & Academia
- Simi-retried since 2025
- Twitter: @edwardzpeng
- https://sites.google.com/site/zhiniangpeng

This talk includes many joint work with researchers From Kunlun Lab & HUST.

Agenda

Chapter1: Bug Hunting with LLM
Chapter2: Bug Hunting with LLM & Agent
Chapter3: Highly Automated Bug Hunting
Chapter4: AI for Crypto
Chapter5: AI for Cybersecurity
Chapter6: AI for Security Researcher
Chapter7: The End

CHAPTER 1

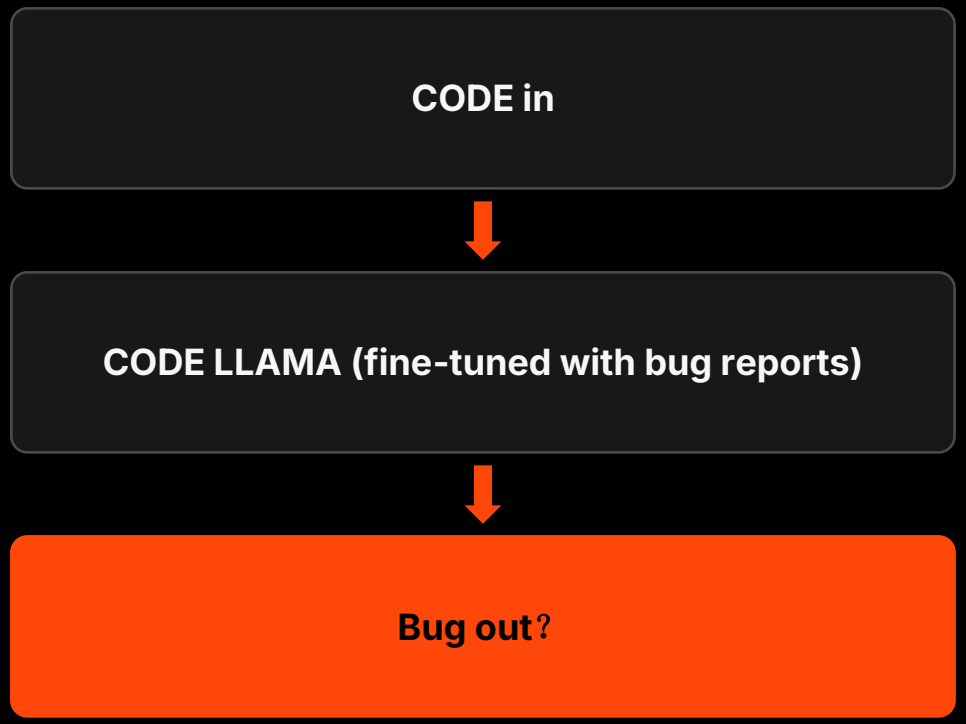
Bug Hunting with LLM

The failed version

Detect Bugs with Code Llama in 2023

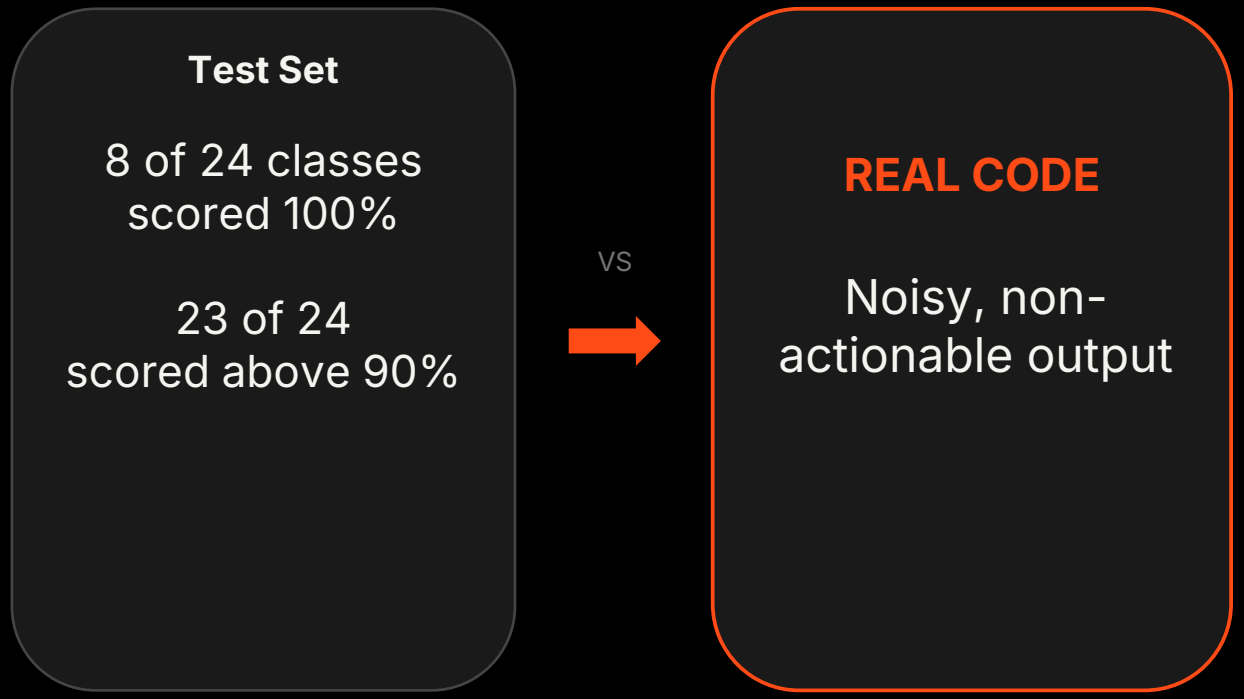
Fine-tuned:

40K python bug,
37k java bug,
40k clean code



Code sample in —> Bug out?

Works well on the Benchmark, Useless on Real Code



Works like some static code scanning tools we've used before

Why did it fail?

- Wrong target: classification ≠ vulnerability hunting
- Wrong capability: more SFT data ≠ deeper reasoning
- Pattern overfit: CVE features ≠ security invariants
- Missing context: code snippets ≠ full context of the target
- No threat model: no security boundary, entry point, or security goal
- Not verifiable: it could not run, debug, or verify
- No durable state: one answer ≠ hypothesis → evidence → revision

We were too early to do bug hunting with LLM in 2023

Things changed in late 2025

Better LLM and Stronger Reasoning

GPT 5.2, Opus 4.5 ……

Longer Context

All repositories, call chains, object lifetimes, and trust boundaries can be fit in Context

Better Agent Workflows

ReAct, Plan-and-Execute, Chain of Thoughts, Multi-Agent….

More Tools

MCP, CLI, A2A, Skill……

The breakthrough was not just a better model. It was a better system around it.

CHAPTER 2

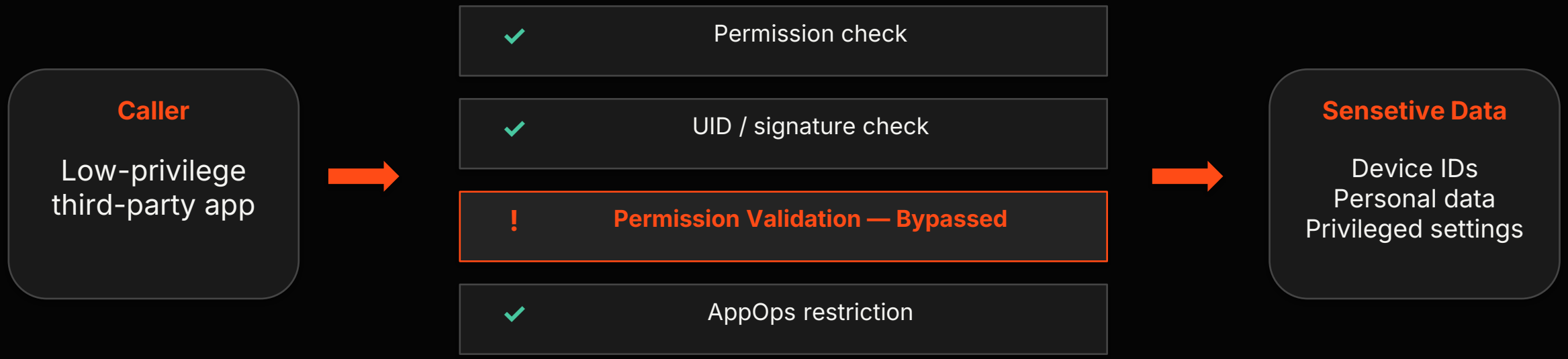
So, Let’s try again in 2025!

Bug Hunting with LLM & Agent

Access Control Vulnerability in Customized Android Systems

Phone | Watch | Band | TV | In-Vehicle | IoT

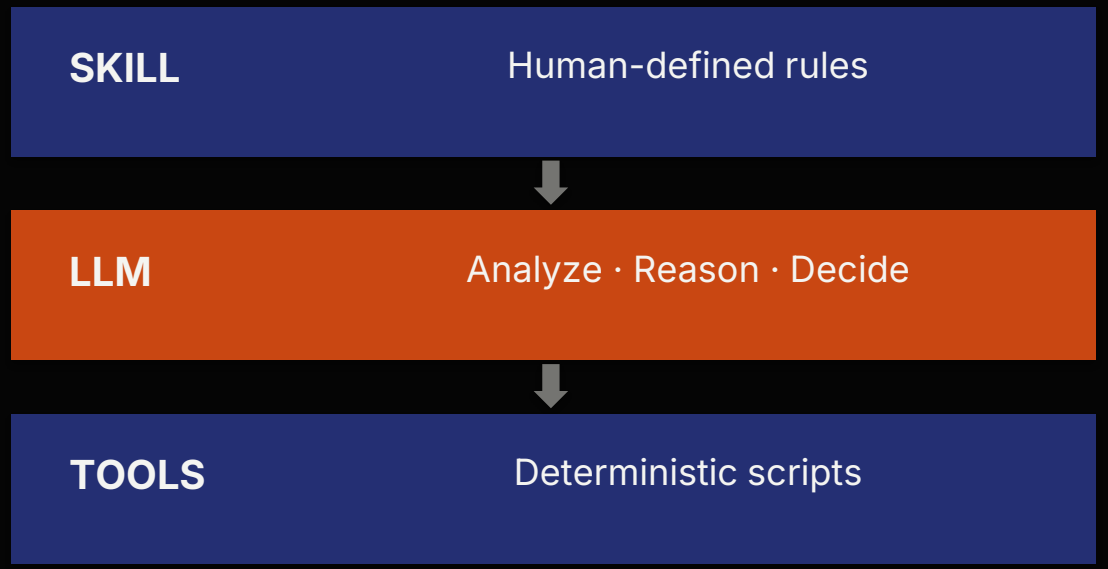
Many vendors · Complex firmware · OEM services in every ROM



LLM-Driven Access-Control Research on Customized Android

Joint work with X0ev · Wh1tc (Kunlun Lab) · Zhiniang Peng

Dec 2025–Jan 2026



01 Bug hunting

Analyze high-risk code paths and generate candidate findings.

02 On-Device Validation

Generate, run, and revise PoCs on real devices.

Tools for the Agent

Firmware Unpacking

Extract APKs from system, vendor, and product partitions.

Jadx Decomplication

Turn system APKs into readable Java code.

Manifest Scan

Map permissions, actions, and components.

Indexing

Index file paths, packages, and classes.

Task Generation

Select exported, high-risk system components.

ADB + Logcat

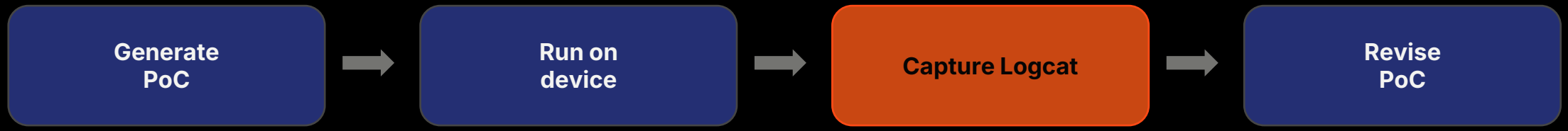
Invoke APIs and capture access-control evidence.

Tools are deterministic. The skill defines when and how the agent uses the tools.

Two-Step Reasoning over High-Risk APIs

STEP 1	**Understand the behaviors**	Which identities, parameters, and states lead to a sensitive action?
STEP 2	**Decide if it is unauthorized**	Is the action beyond this caller's intended privilege? If yes, consider a candidate finding.

Validation on Real Devices



FAILURE → REVISE → RETRY

Common failure

- Missing call order
- Missing required state
- Data dependency unmet
- Permission / environment unmet

Codex GPT-5.2 (Extra High) · TARGETS OPPO / HONOR / Xiaomi / Samsung / Google · VALIDATION Real devices

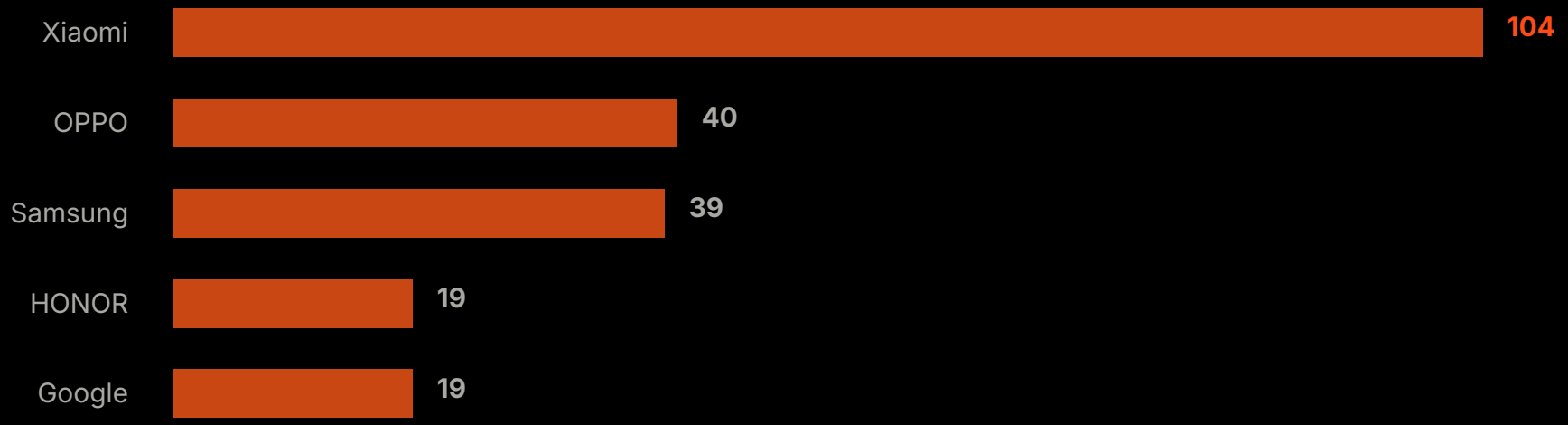
>110

Confirmed vulnerabilities · 183 reports

< $1

Average cost per PoC · about 2 iterations

HIGH-RISK FINDINGS BY TARGET



There are a lot more bug here, but we stop hunting after 2 month of repetitive work because it's too boring.

From Chat to Agent

2023 · Chat

Could this code look like a known bug pattern?

LATE 2025 · Agent

Understand the system, investigate and validate the finding with a PoC.

AI

- Uses tools
- Performs scoped analysis
- Generate report and PoC

Researcher

- Selects attack surfaces
- Builds the harness and skills
- Validates value and owns the result

Human & AI Co-Research

CHAPTER 3

Highly Automated Bug Hunting

Feb 2026, Anthropic Claim:
Opus 4.6 can find vulnerabilities at scale.

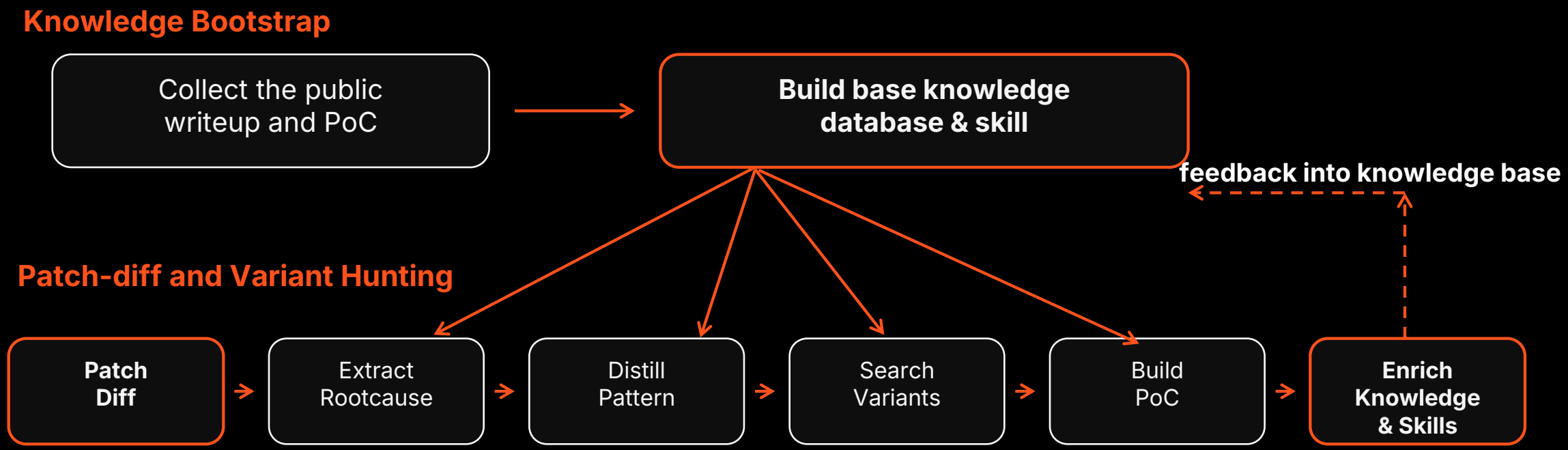
With better model,
let’s try to do highly Automated Bug hunting

In the previous chapter,
researcher need to select attack surface, build harness and skill for security invariant.

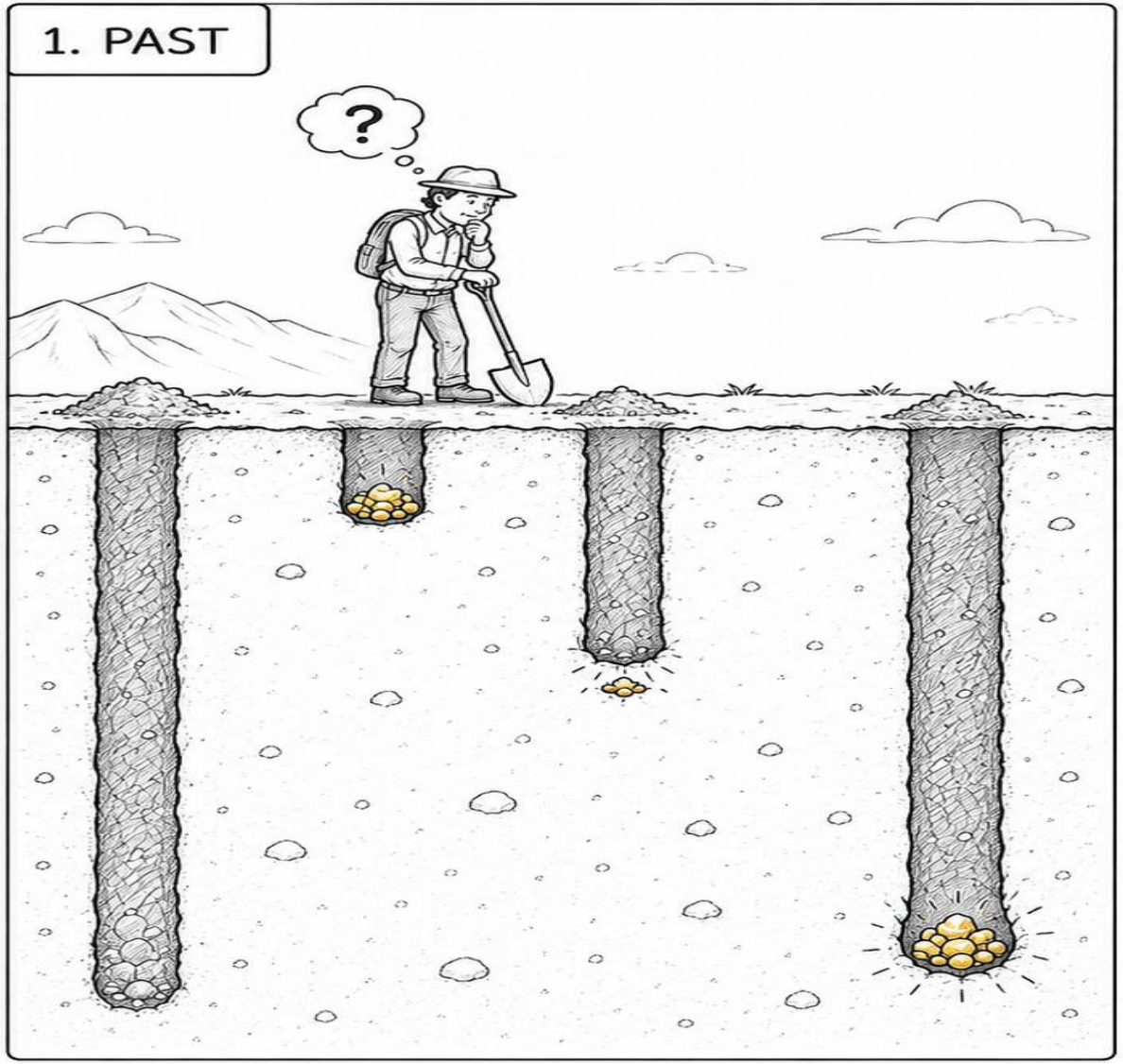
With new and stronger model & agent, AI can do it if we have enough data (from the patch).

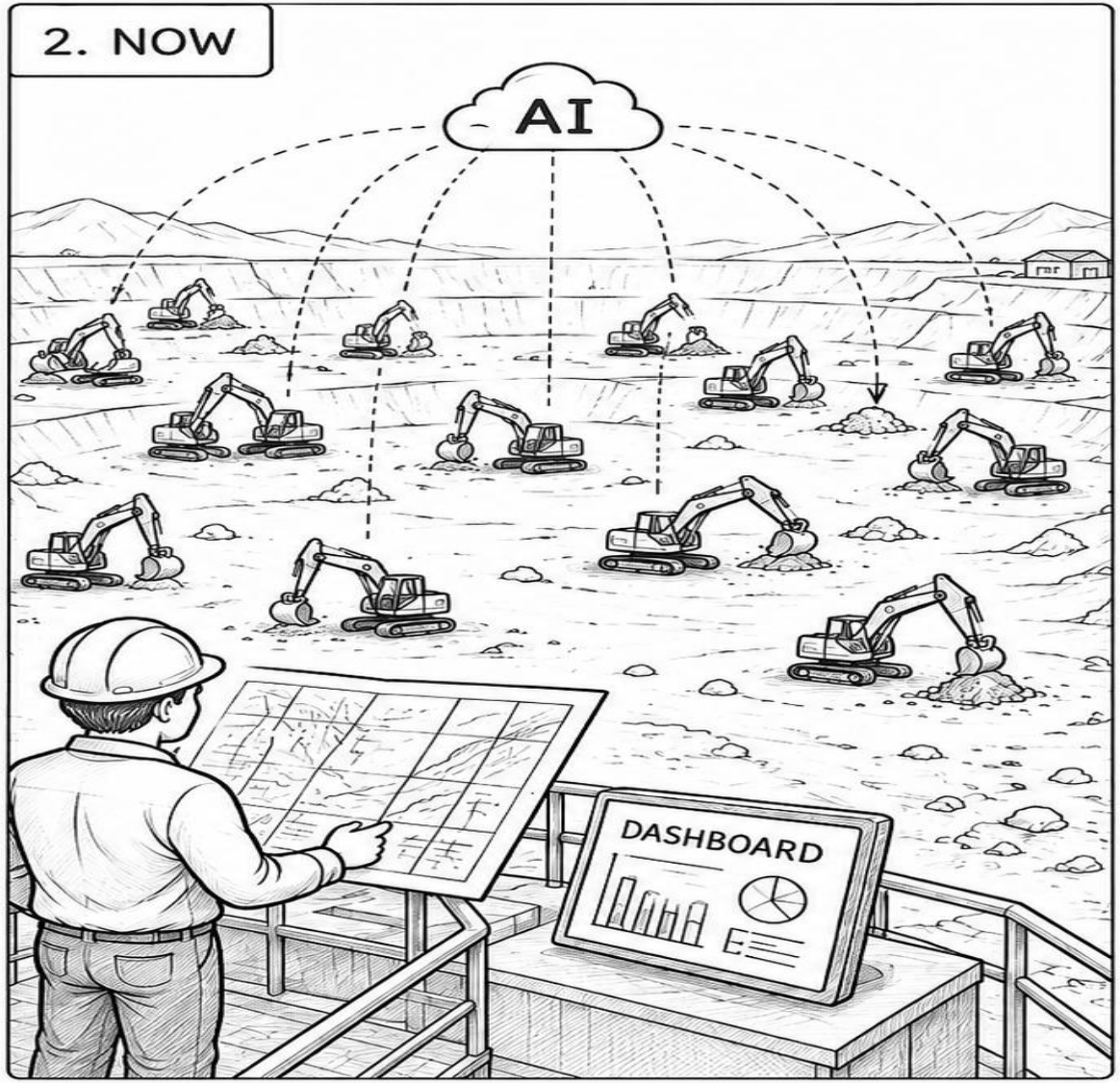
Diffract: From Patch to Vulnerability Variants

Joint work with Yunpeng Tian | @___2st | Zhiniang Peng



Difftract on Microsoft Windows (Kernel & Services)





Claude OPUS-4.6 to 4.8 · on Microsoft Windows (Kernel & Services)

200+

Confirmed vulnerabilities · 400+ reports

RCE, LPE, InfoLeak across different modules

You can get a lot bug easily if you willing to burn enough token.
Bug hunting on Windows become boring in 2026.

LLM bug hunting in 2026

Dec 2025 to Feb 2026

Older-generation model

Bug hunting works with a better harness

Example: GPT-5.2
(We use in chapter 2)

After Feb 2026

Good-enough model

Almost fully automated bug hunting is possible

Opus 4.6, Kimi K3
DeepSeek V4, GPT-5.4, GLM-5.3

Now

SOTA model

Sometime you just need to make a wish

The model can improve its own workflow

All this happened within six months.

Researcher here to harness and improve AI

Older-generation model	Keep the whole process on track Break down tasks, prepare context and tools, and check each step
Good-enough model	Monitor the full loop Provide key context, system access, or debugging support
SOTA model	Push the model boundary Digest it’s output, study what it misses, add new context or methods and try again

How about exploiting bugs?

It’s almost the same story

Bug Hunting with SOTA model in 2026:

/goal Give me a vulnerability

(a lot of low hanging fruit for AI,
Because there are huge backlog of old bugs)

/goal Give me an iOS 0-Click RCE full chain exploit?

(Probably can’t get it from your $200 subscription)

/goal Give me an iOS 0-Click RCE full chain exploit?

**(How about using OpenAI's internal model, with 10,000 agents working 88 hours.
Which solve the N-S equations?)**

Bug hunting has evolved into some kind of token economics.

This happened within half year through our story.

Is vulnerability research dead?

01 Currently, we are in a 'bug for free' era because there's a huge backlog of old bugs.

02 After the chaos, it will eventually settle into a steady state.

03 AI will hit its limits. It's exactly researcher’s job to push past those boundaries. Until AI can improve himself.

Vulnerability research haven’t died now, but it has completely changed in less than six months.

CHAPTER 4

AI for Crypto

Bug hunting is boring now, let’s try something else.
How about Crypto?

A little Background about Myself

PhD in Cryptography

Four years research on Crypto 2013-2017

Back to Practical Security

Returned to real systems and offensive research after 2017 (Math is too hard for me)

Never break a strong crypto

Could AI help me become a real codebreaker?

First Try: Revisit my own design

Asked GPT-5.6 to prove an unpublished attribute-based signcryption scheme, which I couldn't prove myself.

20 minutes later, it explained why no proof would work:

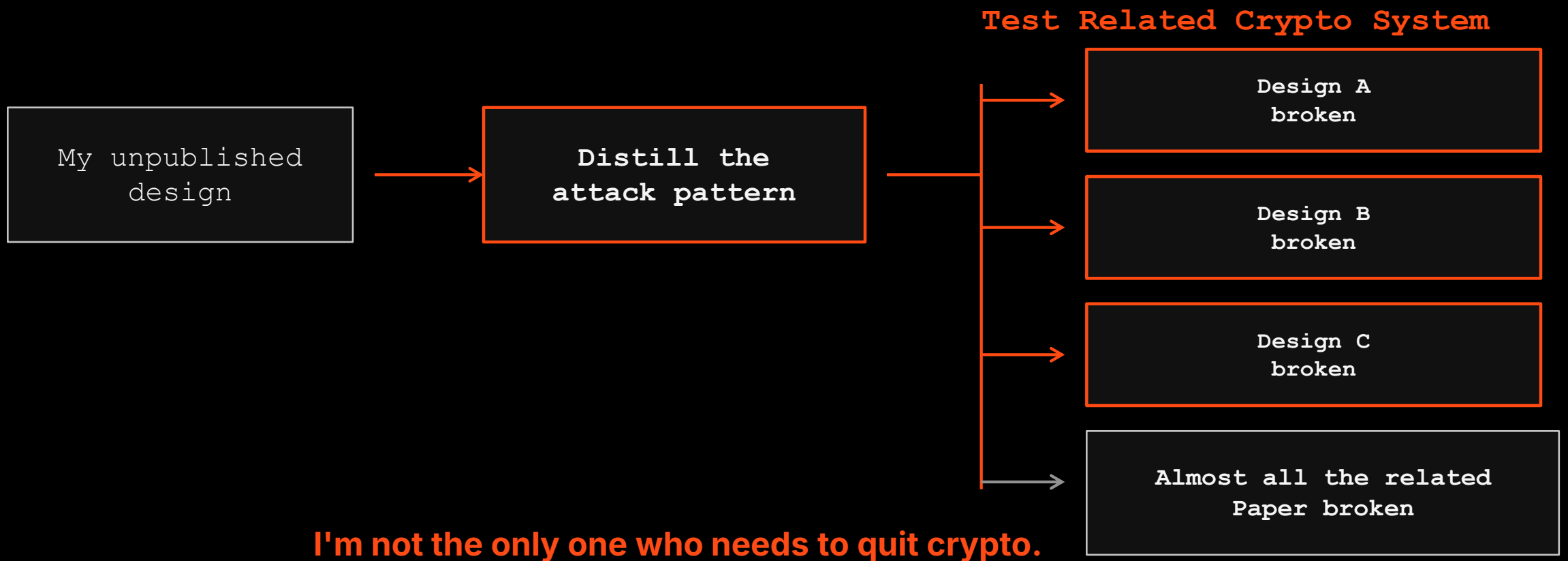
it had found an attack 💣.

Walking away from crypto was the right move for me. GPT outperforms my four years of research(Oˊ·д·)/



Second Try: GPT broke almost all the related paper

GPT-5.6 found a structural weakness across a family of related crypto constructions.

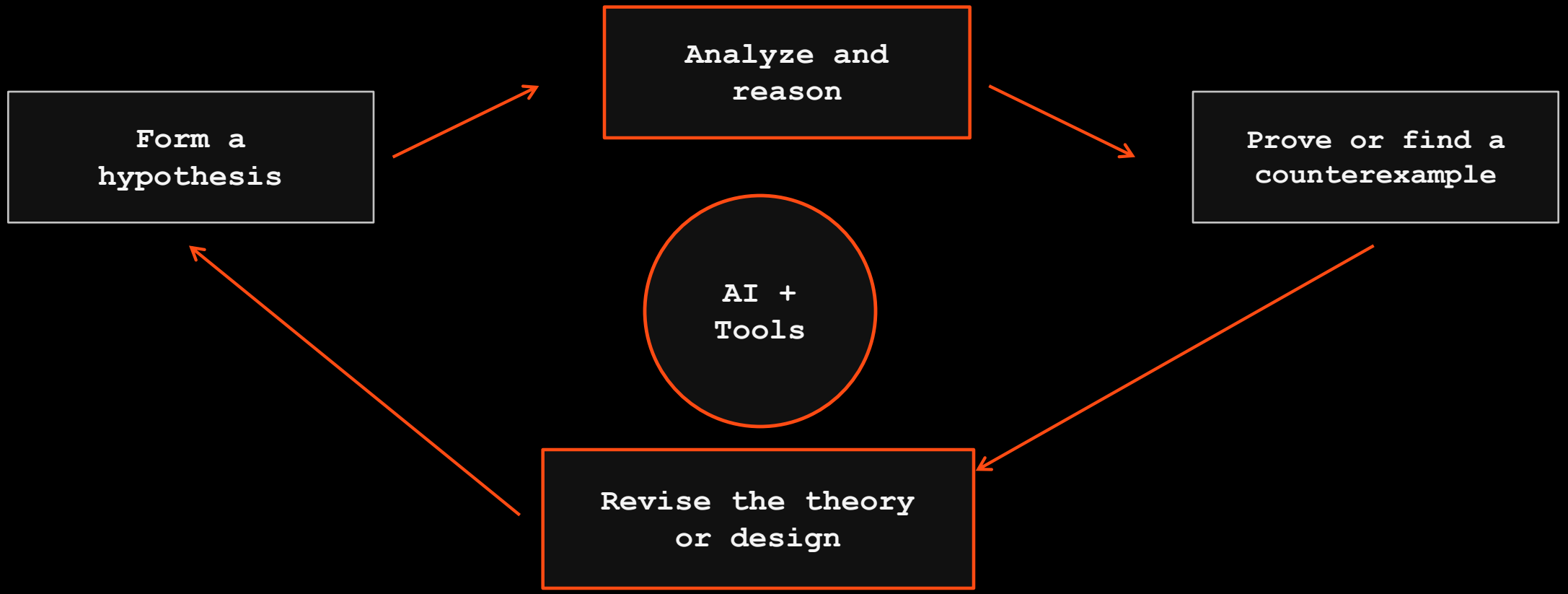


I'm not the only one who needs to quit crypto.

I wouldn't be surprised if AI break major crypto or some underlying hard math problems in near future.

AI accelerates all scientific research

Cybersecurity, Software, Cryptography, and Mathematics take the first hit



The debate is whether it can be truly creative. But creativity is hard to quantify or define, we can't prove AI will never possess it.

Image a world with embodied AI, World Models, Physical Native Intelligence :)

CHAPTER 5

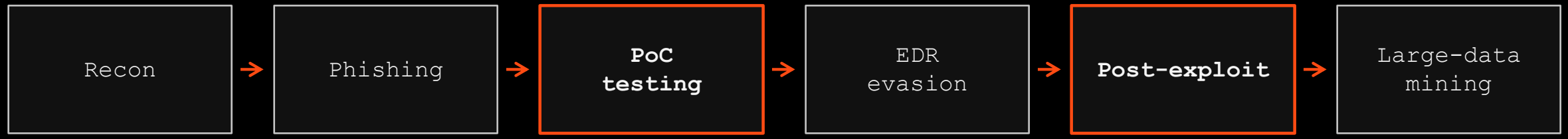
AI for Cybersecurity

AI will change the world, cyber world will take the first hit

AI accelerates the red-teaming

In our red team simulations, undergraduate students with:
Zcode + GLM-5.2 + tools + simple skills
can easily work like a good red teamers across the full workflow.

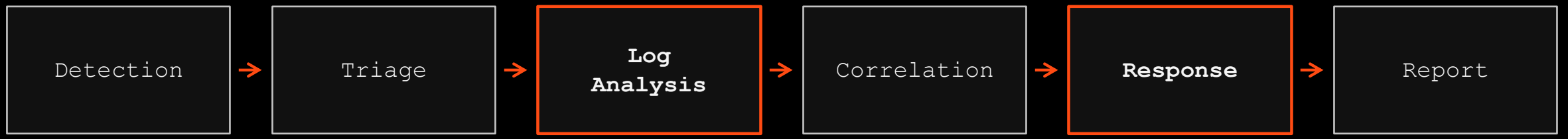
AI-ASSISTED:



AI accelerates DFIR

In our DFIR projects:

AI-ASSISTED:



Funny that: logs, scripts, files, and other artifacts left behind by attackers: contain keywords such as :

'Pentest', 'Red team', 'CTF', 'Security audit'

Attackers are using these keywords to trick AI, even in some APT event with 2M+ crypto theft.

AI Attacker vs AI Defender

Exploitation driven by AI already come
Massive Exploitation is coming



Image everyone can just make a wish:
/goal get me 10 bitcoin, send to my wallet.
/goal get me a secret document from government.

\Anthropic is right that about protect human from AI (Begin at the cyber world)

But I disagree with their approach.

Big Vendor Accelerate Bug fixing

Advanced LLM models + Hardware Resource + Source code & Bug report = Huge mount of Bugs fxied

Find -> validate -> fix -> ship
before exploitation
Racing with attackers

Smaller vendors with less resource face more exploitation.
A lot bugs will be found there by attacker!

The market of Cybersecurity will grow quickly with AI

IT asset value

Grow with AI



x

Security threat

Grow with AI



=

Value of Cybersecurity



Cybersecurity will be one of the first AI adoption!

We need more than just fixing bugs in defensive

DEFENSE / DETECTION / RESPONSE / OTHERS

haven't been fully automated by LLMs yet.

Many products claim AI, but killer-level defensive product still hard to find.

This gap is a challenge and an opportunity.

The next opportunity

01

AI makes attackers faster and stronger.

02

Bug fixing is starting to benefit from LLMs.

03

But traditional defense, detection, and response haven't been fully automated by LLMs yet.

The gap is full of challenge and opportunity.

CHAPTER 6

AI for Security Researcher

Hack for fun and Hack for profit?

Vulnerability research used to be really good job. Researcher are spoiled.

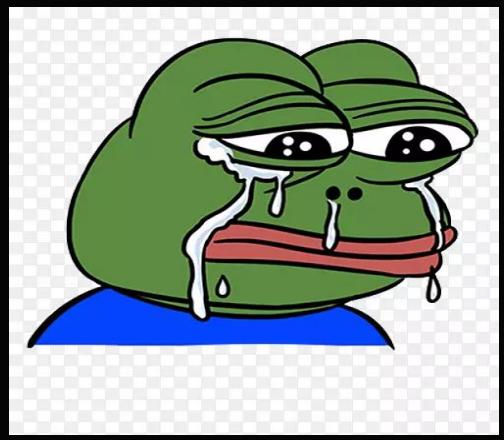
As a vulnerability researcher, you will always experience the "the lyricism of logic", "the joy of statistics" and "the beauty of coincidence". Sometimes you feel like a scientist, engineer, detective, artist or sometime a retard.

But this is before 2026

After 2026 The knowledge moat is broken.

Intelligence is cheap for sell.

Vulnerability research brings lesser the joy of intellectual.



Many researchers I know are very pessimistic.

Hack for fun, with AI?

The more I use AI, the more I feel like a robot myself.

Straight highways & cable cars instead of foggy climbs.

lyricism

We may lose the grit of conquest?

We miss it but will never go back to the old-school bug hunting.

I used to record my CVEs before 2026, most of them mean something for me.

CVE-2025-62564	CVE-2025-53739	CVE-2025-20063	CVE-2024-29156	CVE-2023-28296	CVE-2022-30226	CVE-2021-26885	CVE-2020-1590	CVE-2020-1360	CVE-2020-1189	CVE-2020-1000	CVE-2020-0697
CVE-2025-62563	CVE-2025-53737	CVE-2025-8292	CVE-2024-26198	CVE-2023-28243	CVE-2022-30157	CVE-2021-26871	CVE-2020-1552	CVE-2020-1357	CVE-2020-1188	CVE-2020-0989	CVE-2020-0648
CVE-2025-62561	CVE-2025-53736	CVE-2025-0587	CVE-2024-21435	CVE-2023-24929	CVE-2022-29113	CVE-2021-26870	CVE-2020-1550	CVE-2020-1356	CVE-2020-1187	CVE-2020-0985	CVE-2020-0641
CVE-2025-62559	CVE-2025-53735	CVE-2025-0236	CVE-2024-21433	CVE-2023-24928	CVE-2022-29108	CVE-2021-26869	CVE-2020-1549	CVE-2020-1352	CVE-2020-1186	CVE-2020-0983	CVE-2020-0638
CVE-2025-62556	CVE-2025-50155	CVE-2025-0235	CVE-2024-21426	CVE-2023-24927	CVE-2022-29103	CVE-2021-24088	CVE-2020-1548	CVE-2020-1347	CVE-2020-1185	CVE-2020-0944	CVE-2020-0636
CVE-2025-60727	CVE-2025-49726	CVE-2025-0234	CVE-2024-21409	CVE-2023-24926	CVE-2022-26930	CVE-2021-24077	CVE-2020-1538	CVE-2020-1346	CVE-2020-1184	CVE-2020-0942	CVE-2020-0635
CVE-2025-60726	CVE-2025-49725	CVE-2024-58113	CVE-2024-21384	CVE-2023-24925	CVE-2022-24547	CVE-2021-24072	CVE-2020-1528	CVE-2020-1344	CVE-2020-1166	CVE-2020-0936	CVE-2020-0616
CVE-2025-60710	CVE-2025-49724	CVE-2024-58048	CVE-2024-21329	CVE-2023-24924	CVE-2022-24454	CVE-2021-3750	CVE-2020-1524	CVE-2020-1337	CVE-2020-1165	CVE-2020-0935	CVE-2020-0518
CVE-2025-59290	CVE-2025-49723	CVE-2024-58045	CVE-2024-20694	CVE-2023-24913	CVE-2022-23290	CVE-2021-1722	CVE-2020-1522	CVE-2020-1317	CVE-2020-1164	CVE-2020-0934	CVE-2020-0516
CVE-2025-59282	CVE-2025-49712	CVE-2024-57956	CVE-2024-20691	CVE-2023-24909	CVE-2022-23285	CVE-2021-1718	CVE-2020-1521	CVE-2020-1312	CVE-2020-1163	CVE-2020-0900	CVE-2019-18371
CVE-2025-59260	CVE-2025-49711	CVE-2024-43594	CVE-2024-9419	CVE-2023-24907	CVE-2022-23270	CVE-2021-1690	CVE-2020-1519	CVE-2020-1309	CVE-2020-1158	CVE-2020-0899	CVE-2019-18370
CVE-2025-59245	CVE-2025-49701	CVE-2024-43583	CVE-2024-0088	CVE-2023-24887	CVE-2022-22050	CVE-2021-1689	CVE-2020-1518	CVE-2020-1307	CVE-2020-1157	CVE-2020-0897	CVE-2019-8162
CVE-2025-59220	CVE-2025-49698	CVE-2024-43495	CVE-2024-0087	CVE-2023-24886	CVE-2022-22024	CVE-2021-1688	CVE-2020-1517	CVE-2020-1306	CVE-2020-1156	CVE-2020-0896	CVE-2019-6487
CVE-2025-59193	CVE-2025-49690	CVE-2024-43470	CVE-2023-46138	CVE-2023-24885	CVE-2022-22022	CVE-2021-1687	CVE-2020-1516	CVE-2020-1305	CVE-2020-1155	CVE-2020-0871	CVE-2019-6186
CVE-2025-59188	CVE-2025-49687	CVE-2024-43467	CVE-2023-42820	CVE-2023-24884	CVE-2022-21999	CVE-2021-1686	CVE-2020-1512	CVE-2020-1304	CVE-2020-1151	CVE-2020-0868	CVE-2019-6184
CVE-2025-59186	CVE-2025-49665	CVE-2024-43460	CVE-2023-42819	CVE-2023-24883	CVE-2022-21992	CVE-2021-1681	CVE-2020-1511	CVE-2020-1283	CVE-2020-1146	CVE-2020-0865	CVE-2019-1474
CVE-2025-59184	CVE-2025-48812	CVE-2024-43455	CVE-2023-36898	CVE-2023-24876	CVE-2022-21980	CVE-2021-1680	CVE-2020-1485	CVE-2020-1282	CVE-2020-1144	CVE-2020-0864	CVE-2019-1374
CVE-2025-58738	CVE-2025-47991	CVE-2024-43454	CVE-2023-36792	CVE-2023-24872	CVE-2022-21974	CVE-2021-1659	CVE-2020-1484	CVE-2020-1278	CVE-2020-1139	CVE-2020-0863	CVE-2019-1342
CVE-2025-58737	CVE-2025-47986	CVE-2024-38263	CVE-2023-36704	CVE-2023-24870	CVE-2022-21971	CVE-2021-1651	CVE-2020-1475	CVE-2020-1277	CVE-2020-1137	CVE-2020-0858	CVE-2019-1340
CVE-2025-58736	CVE-2025-47174	CVE-2024-38262	CVE-2023-36418	CVE-2023-24868	CVE-2022-21888	CVE-2021-1650	CVE-2020-1474	CVE-2020-1276	CVE-2020-1134	CVE-2020-0854	CVE-2019-1317
CVE-2025-58735	CVE-2025-47172	CVE-2024-38260	CVE-2023-36395	CVE-2023-24867	CVE-2022-21881	CVE-2021-1649	CVE-2020-1472	CVE-2020-1274	CVE-2020-1131	CVE-2020-0849	CVE-2019-1292
CVE-2025-58734	CVE-2025-33068	CVE-2024-38258	CVE-2023-36393	CVE-2023-24866	CVE-2022-21878	CVE-2020-17120	CVE-2020-1465	CVE-2020-1273	CVE-2020-1130	CVE-2020-0844	CVE-2019-1253
CVE-2025-58733	CVE-2025-32704	CVE-2024-38231	CVE-2023-35624	CVE-2023-24865	CVE-2022-21837	CVE-2020-17097	CVE-2020-1461	CVE-2020-1270	CVE-2020-1125	CVE-2020-0841	CVE-2018-20746
CVE-2025-58732	CVE-2025-31171	CVE-2024-38228	CVE-2023-35343	CVE-2023-24863	CVE-2022-21835	CVE-2020-17092	CVE-2020-1441	CVE-2020-1269	CVE-2020-1124	CVE-2020-0835	CVE-2018-20696
CVE-2025-58731	CVE-2025-30381	CVE-2024-38225	CVE-2023-35326	CVE-2023-24858	CVE-2021-43248	CVE-2020-17089	CVE-2020-1427	CVE-2020-1264	CVE-2020-1123	CVE-2020-0822	CVE-2018-20694
CVE-2025-58730	CVE-2025-30376	CVE-2024-38099	CVE-2023-35324	CVE-2023-24857	CVE-2021-43223	CVE-2020-17077	CVE-2020-1424	CVE-2020-1257	CVE-2020-1122	CVE-2020-0819	CVE-2018-20693
CVE-2025-58728	CVE-2025-29979	CVE-2024-38097	CVE-2023-35323	CVE-2023-24856	CVE-2021-43216	CVE-2020-17076	CVE-2020-1405	CVE-2020-1244	CVE-2020-1121	CVE-2020-0808	CVE-2018-20692
CVE-2025-55683	CVE-2025-29957	CVE-2024-38077	CVE-2023-35313	CVE-2023-23413	CVE-2021-42321	CVE-2020-17075	CVE-2020-1404	CVE-2020-1235	CVE-2020-1120	CVE-2020-0805	CVE-2018-20690
CVE-2025-55676	CVE-2025-29823	CVE-2024-38076	CVE-2023-35306	CVE-2023-23406	CVE-2021-42297	CVE-2020-17074	CVE-2020-1399	CVE-2020-1233	CVE-2020-1109	CVE-2020-0800	CVE-2018-20689
CVE-2025-55243	CVE-2025-29819	CVE-2024-38074	CVE-2023-35302	CVE-2023-23403	CVE-2021-42294	CVE-2020-17073	CVE-2020-1394	CVE-2020-1231	CVE-2020-1094	CVE-2020-0797	CVE-2018-10812
CVE-2025-54913	CVE-2025-29794	CVE-2024-38073	CVE-2023-35296	CVE-2023-21801	CVE-2021-41366	CVE-2020-17070	CVE-2020-1393	CVE-2020-1222	CVE-2020-1090	CVE-2020-0794	CVE-2017-7269
CVE-2025-54906	CVE-2025-27747	CVE-2024-38072	CVE-2023-32085	CVE-2023-21693	CVE-2021-40485	CVE-2020-17014	CVE-2020-1392	CVE-2020-1217	CVE-2020-1086	CVE-2020-0789	
CVE-2025-54900	CVE-2025-27729	CVE-2024-38071	CVE-2023-32042	CVE-2023-21684	CVE-2021-38657	CVE-2020-16980	CVE-2020-1385	CVE-2020-1211	CVE-2020-1084	CVE-2020-0786	
CVE-2025-54898	CVE-2025-27521	CVE-2024-38024	CVE-2023-32041	CVE-2023-21683	CVE-2021-36970	CVE-2020-16900	CVE-2020-1375	CVE-2020-1209	CVE-2020-1077	CVE-2020-0785	
CVE-2025-54896	CVE-2025-27471	CVE-2024-38023	CVE-2023-32040	CVE-2022-38036	CVE-2021-34527	CVE-2020-16879	CVE-2020-1373	CVE-2020-1204	CVE-2020-1068	CVE-2020-0780	
CVE-2025-54111	CVE-2025-25218	CVE-2024-38015	CVE-2023-32039	CVE-2022-35793	CVE-2021-31966	CVE-2020-16853	CVE-2020-1372	CVE-2020-1201	CVE-2020-1038	CVE-2020-0777	
CVE-2025-53804	CVE-2025-21400	CVE-2024-35261	CVE-2023-32017	CVE-2022-35755	CVE-2021-28450	CVE-2020-16852	CVE-2020-1366	CVE-2020-1199	CVE-2020-1029	CVE-2020-0754	
CVE-2025-53803	CVE-2025-21199	CVE-2024-35254	CVE-2023-29367	CVE-2022-35749	CVE-2021-28436	CVE-2020-16851	CVE-2020-1364	CVE-2020-1196	CVE-2020-1011	CVE-2020-0753	
CVE-2025-53789	CVE-2025-21174	CVE-2024-30100	CVE-2023-29366	CVE-2022-35746	CVE-2021-28351	CVE-2020-8741	CVE-2020-1362	CVE-2020-1191	CVE-2020-1010	CVE-2020-0747	
CVE-2025-53768	CVE-2025-21082	CVE-2024-29989	CVE-2023-28309	CVE-2022-34690	CVE-2021-28347	CVE-2020-3808	CVE-2020-1361	CVE-2020-1190	CVE-2020-1002	CVE-2020-0730	

I got much more CVE in 2026 than all the past years.

But I cannot remember most of them in details.

For me, they are just numbers.

There is no fun, if you only care about the numbers.

The beauty are actually still there:

If you really look into how AI thinking there, you will learn new things.
Digest it, you can guide AI find more beauty.

"the lyricism of logic", "the joy of statistics" and "the beauty of coincidence“ are actually still there.

But I was just too busy to working with huge numbers in 2026 because huge mount of existing bugs.
I feel boring, because I choose to ignore the beauty but value the number.

The joy will back after the chaos!
When we really look into the bug itself.

Hack for Profit, with AI?

Value goes to the guy spend more token and have access to advance model

But AI can’t do everything, right?

For example, It failed to generate this presentation for me

Get an iOS 0-Click RCE exploit chain with

OpenAI's internal model, with 10,000 agents working 88 hours.

Get an iOS 0-Click RCE exploit chain with

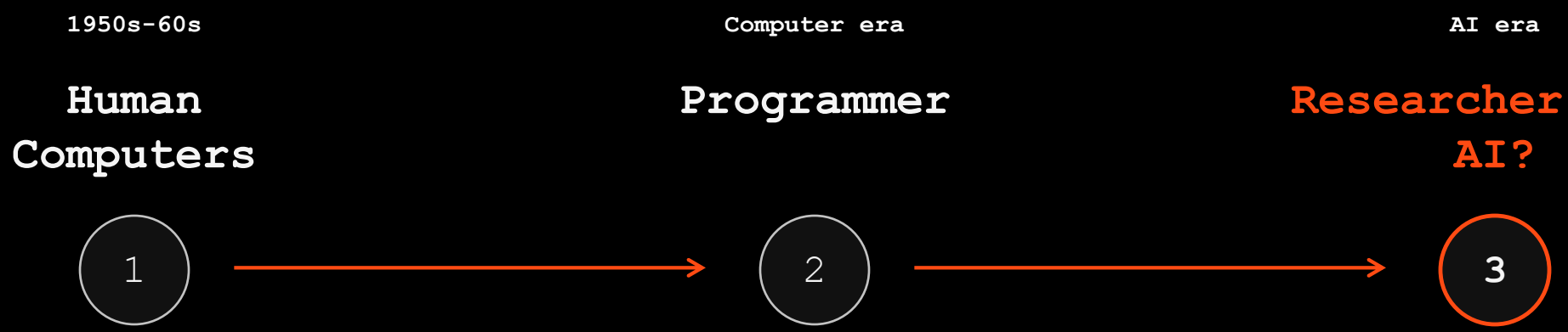
your $200 SOTA subscription

The token gap is our value

But old school bug hunting is the past.

We have to embrace the new tech.

NASA's human computer evolved into programmer, making manual orbital calculations obsolete.



AI won't eliminate talent, but it will redefine what it takes

Looking back at history, technology always made the world a better place. So, we should stay optimistic and excited

Security researchers may take different paths

01

Routine roles shrink

Known bug patterns and repeated work move to AI.

02

Harness AI

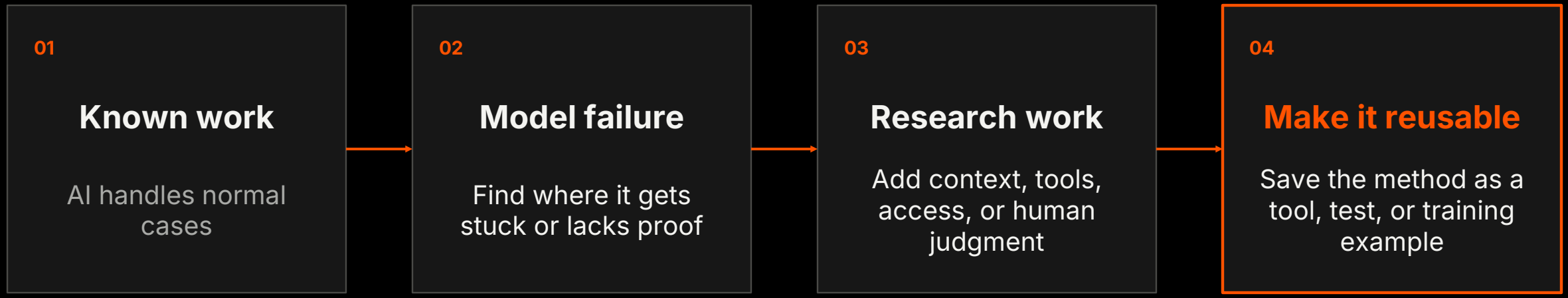
Use AI to expand what you can do.
Digest its output, verify the result and judge its impact.

03

Improve the frontier

Understand AI, study new systems, find model failures, and help AI break the boundary.

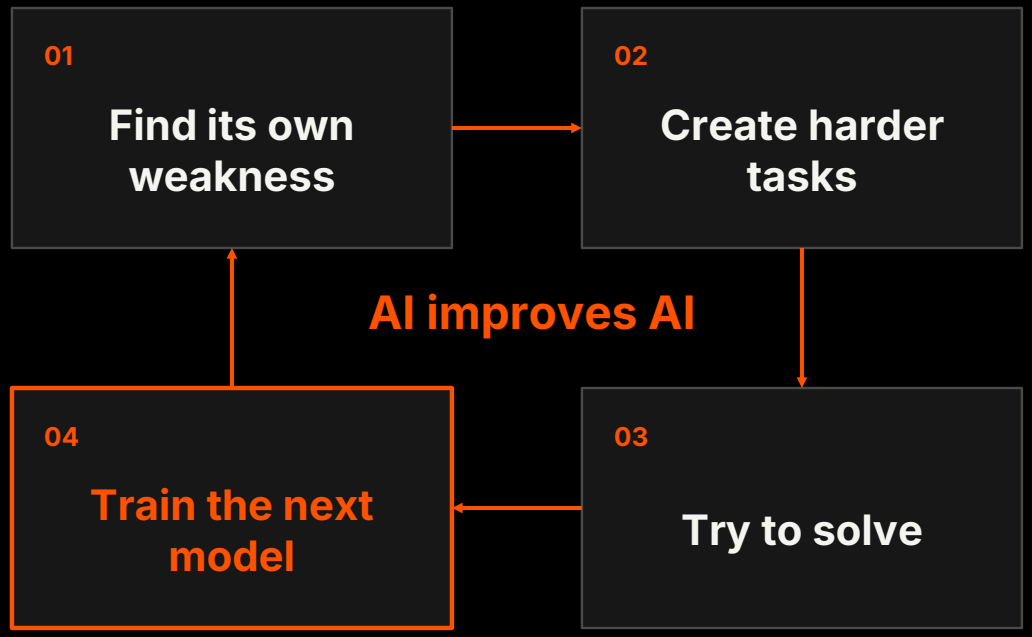
Researchers improve AI



When AI learns this work, researchers move to the next gap.

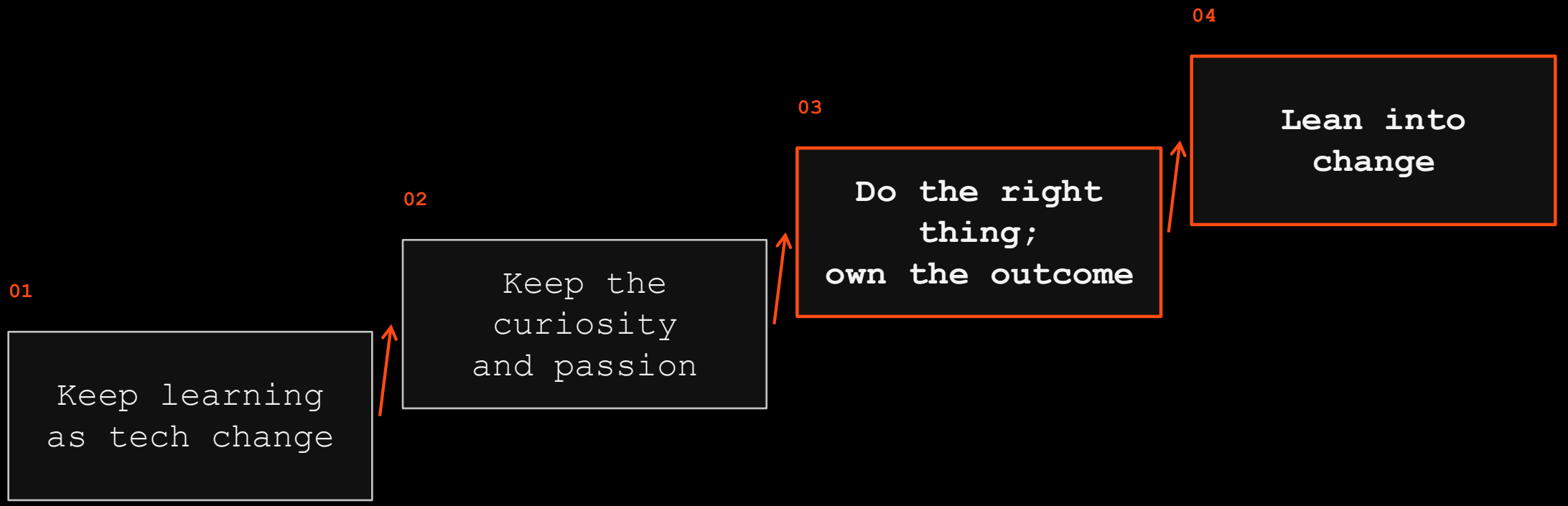
AI improves AI?

A possible end state on vulnerability research



People may still set goals and limits. If AI can do that too, the human role may become very small.

For security researcher



Challenges remain, there definitely has more exciting things yet to come.

CHAPTER 7

The End

In 2026

01 AI Change Vulnerability Research

02 AI Change Crypto Research

03 AI Change Scientific Research

Cybersecurity will be one of the first AI adoption!

(in both offensive and defensive)

Cybersecurity now is full of challenge and opportunity

This is my first-year hacking with LLM, and I have no idea what year two will bring.

Technology will keep evolving, and will make the world better.

We all just a dust compared with the beautiful universe, so just

enjoy the ride.

Thank You!